

Permission Matrix / Endpoint Behaviour Spec for “Ressource permissions” (2nd Milestone)

	Endpoint	admin	Non-admin	Non-logged	Any?	Notes
GET	/users/{id}	yes(privileged)	yes(privileged only for own-id)	Forbidden		
PUT	/users/{id}	Lets say yes. Might be specced that way.	Only self (authid=userid)	Forbidden		
DELE	/users/{id}	Yes	Others = no; self = TBD (archive?)	Forbidden		
GET	/users	yes(privileged)	No (forbidden)	Forbidden		
POST	/users				X Any, no restrictions	SpecialCase: Registering; must we require logging “logging out” for registering. Sending the token voluntary, anyways
GET	/subscriptions/{id}	yes	Only owner=self	Forbidden		
PUT	/subscriptions/{id}	yes	Only owner=self	Forbidden		
DELE	/subscriptions/{id}	yes	Only owner=self	Forbidden		
GET	/subscriptions	yes	No*	Forbidden		
POST	/subscriptions	yes(full edit per spec)	Only for “visible” targets. Own and public boxes only	Forbidden		
GET	/cards/{id}	Yes	Only for parent-box with owner=self or parent-box being public	Forbidden		
PUT	/cards/{id}	Yes	Only for parent-box with owner=self	Forbidden		
DELE	/cards/{id}	Yes	Only for parent-box with owner=self	Forbidden		
GET	/cards	Yes	No	Forbidden		
POST	/cards	Yes	Only for parent box owner = self	Forbidden		
GET	/cardProgress/{id}	Yes	???	Forbidden	TBD remove entity for release 2026-1	Not sure if this endpoint makes sense as such?
PUT	/cardProgress/{id}	Yes	???	Forbidden		
DELE	/cardProgress/{id}	Yes	???	Forbidden		
GET	/cardProgress	Yes	???	Forbidden		
POST	/cardProgress	Yes	???	Forbidden		
GET	/boxes/{id}	Yes	Only if box visible (owner or public)	Only if public ! No delivery of card content!		
PUT	/boxes/{id}	Yes	Only if owner	Forbidden		
DELE	/boxes/{id}	Yes	Only if owner	Forbidden		
GET	/boxes	Yes	No	Forbidden (see public boxes)		
POST	/boxes	Yes	Yes	Forbidden		Constraint on post: owner/creator gets set to posting user
GET	/boxcomments/{id}	Yes	Only for comments that have visible boxes as parents	Forbidden		
PUT	/boxcomments/{id}	Yes	Only: own comments and only change allowed is setting visible=false	Forbidden		
DELE	/boxcomments/{id}	Yes	No	Forbidden		
GET	/boxcomments	Yes	Forbidden	Forbidden		
POST	/boxcomments	Yes	Only after check for box specified = visible	Forbidden		Constraint on post: owner/creator gets set to posting user
POST	/auth/token				No special reason to forbid for logged. Token renewal and such. Query?	Special case
GET	Something about own boxes	Yes	Yes	Forbidden / does not apply		/own-boxes
GET	Something about public boxes	Yes	Yes	Yes (!only public info about boxes)		/public-boxes (derived after careful consideration)
GET	*Something about own subscriptions					// level = challenge nonprio
GET	**Something about “all card of a specified box?	Yes	Alternatively: Supply boxes via box-request; For “visible” boxes only (both cases)	Forbidden (both cases)		Not required if BoxDto sends Cards in Box Info (for logged in users that is) /boxes/{id}/cards Perhaps option otherwise